УНИВЕРСИТЕТ ИТМО

Дисциплина «Тестирование программного обеспечения»

Лабораторная работа 9

Исследование веб интерфейса и API KnowBase

Командный отчёт

Участники команды

Васильев Артём Евгеньевич — группа К3440

Алексеев Андрей Викторович — группа К3441

Дущенко Даниил Александрович — группа К3441

Цатинян Артём Арменович — группа К3439

Объект исследования: локальный учебный портал KnowBase

Дата выполнения: 22 октября 2026 года

Санкт-Петербург
2026

Цель работы

Исследовать согласованность веб-интерфейса и API статей и комментариев, выполнить позитивные и негативные проверки по Swagger и проверить объектную авторизацию комментариев.

Ход работы

Окружение и объём проверки

Windows 11; Chromium 139.0.7258.5; KnowBase backend 1.0.0 и frontend 1.0.0; интерфейс https://127.0.0.1:5173; API http://127.0.0.1:8080; дата проверки 22.10.2026; обычные учебные пользователи labteam_a и labteam_b. Источники ожидаемого поведения — README KnowBase и Swagger запущенного API. Проверены все 13 операций контроллера Pages, включая статьи, комментарии, поиск и теги. Запросы оформлены коллекцией Bruno с окружением lab9 и папками Articles и Comments.

Распределение направлений

Васильев Артём Евгеньевич, К3440: анализ Network и Console.

Алексеев Андрей Викторович, К3441: позитивные и негативные API-проверки.

Дущенко Даниил Александрович, К3441: проверка авторизации комментариев.

Цатинян Артём Арменович, К3439: сопоставление Swagger и результатов, оформление дефекта.

Результаты собраны в общей рабочей сессии; распределение определяет ответственность за разбор и представление разделов.

Наблюдения за веб интерфейсом

Действие	Запрос и результат	Наблюдение
Открытие списка статей	GET /api/v1/pages → 200	Статьи загружены и отображены.
Открытие статьи №9	GET /api/v1/pages/9 → 200	Заголовок и текст совпадают с API.
Создание комментария	POST /api/v1/pages/9/comments → 201	После одного действия создан один комментарий.
Обновление страницы	GET /api/v1/pages/9/comments → 200	Комментарий сохранён.
Редактирование комментария	PUT /api/v1/pages/9/comments/{id} → 200	Текст обновился в интерфейсе.
Удаление комментария	DELETE /api/v1/pages/9/comments/{id} → 204	Комментарий исчез из списка.

При указанных позитивных действиях ошибки JavaScript не зарегистрированы. Ошибки 401, 403, 400 и 404 из негативных API-проверок оценивались отдельно от обычных действий интерфейса; ожидаемый отказ не считался дефектом.

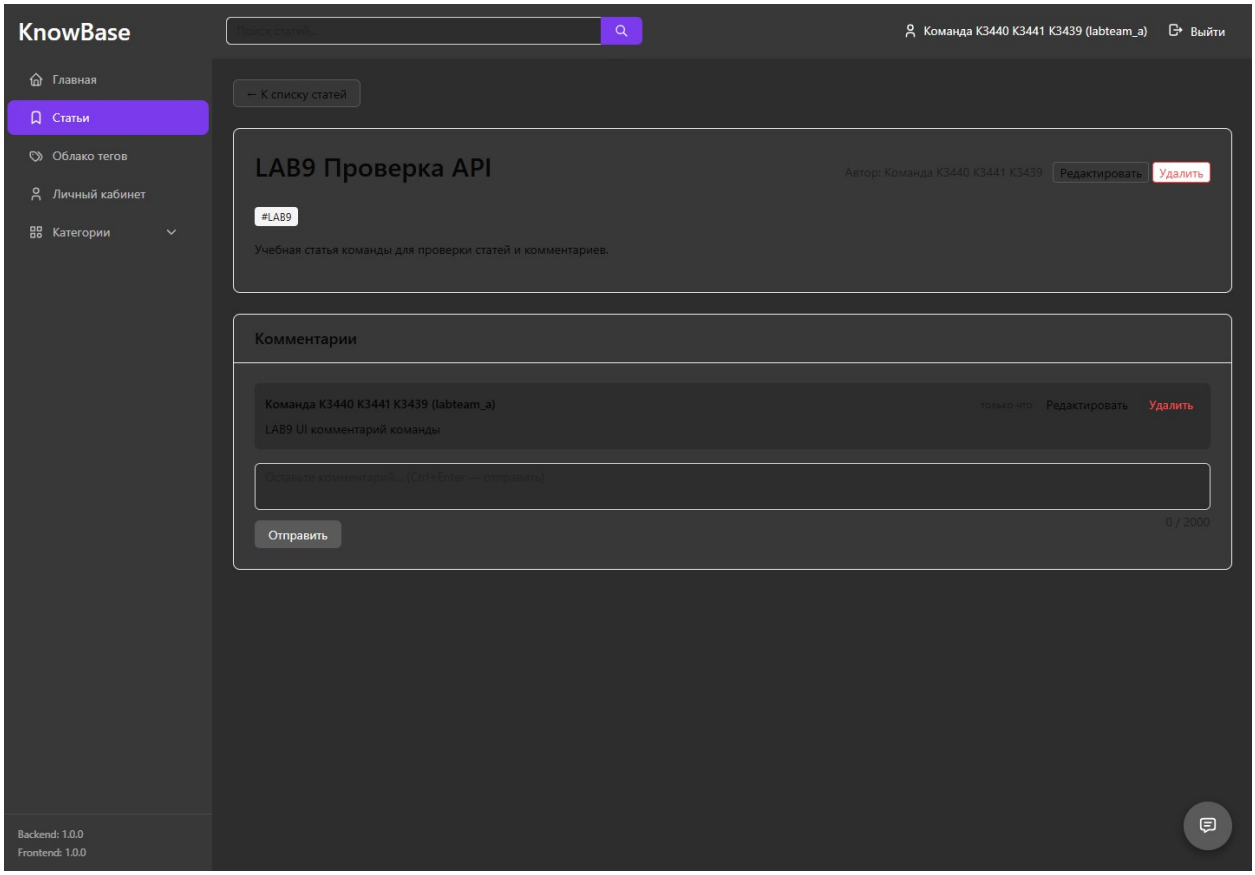


Рисунок 1 Комментарий сохранён после обновления страницы

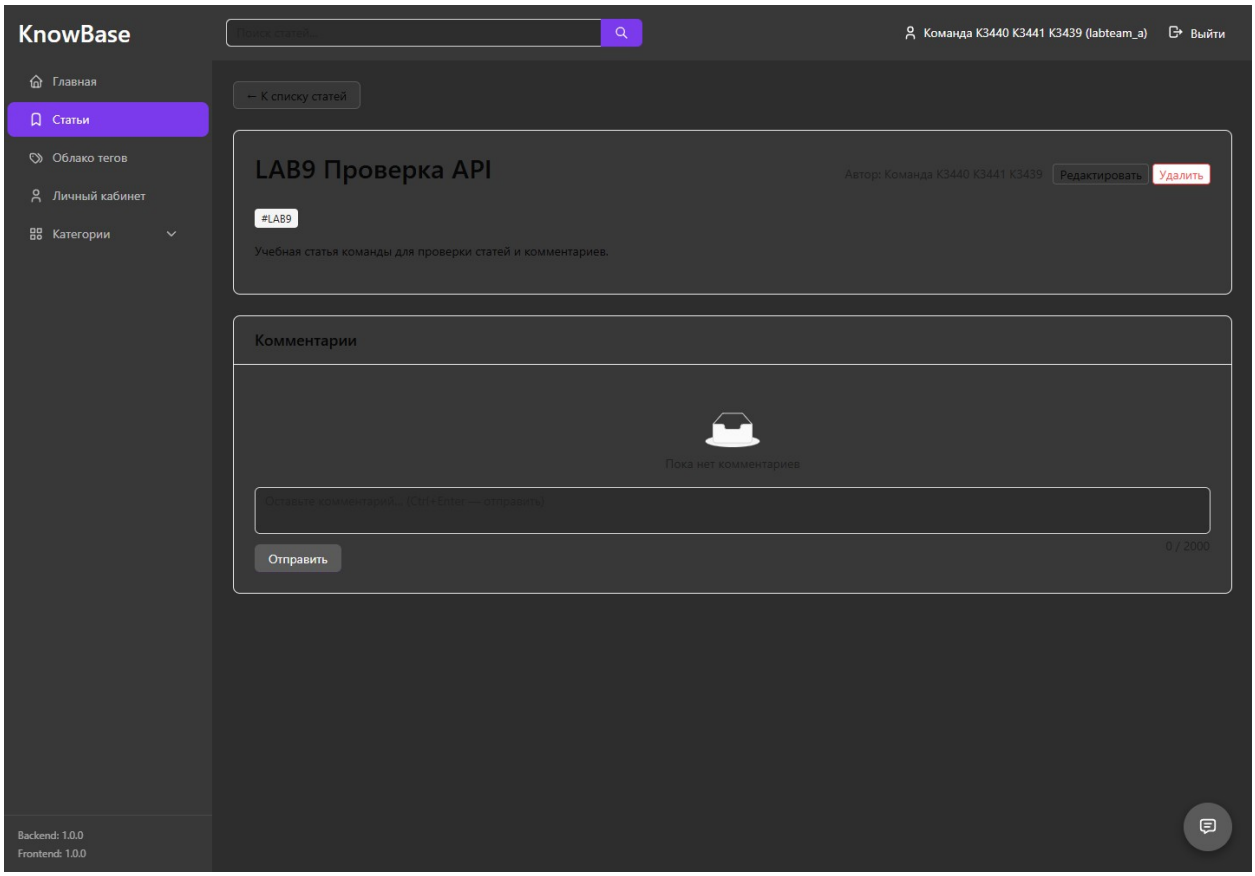


Рисунок 2 Удаление комментария через интерфейс

Матрица API проверок

№ и сценарий	Метод и путь	Ожидание / факт	Итог
API9-01 Список статей	GET /api/v1/pages	200 / 200	Пройдено
API9-02 Список статей без авторизации	GET /api/v1/pages	401 / 401	Пройдено
API9-03 Чтение статьи	GET /api/v1/pages/9	200 / 200	Пройдено
API9-04 Чтение статьи без авторизации	GET /api/v1/pages/9	401 / 401	Пройдено
API9-05 Свои статьи	GET /api/v1/pages/my	200 / 200	Пройдено
API9-06 Свои статьи без авторизации	GET /api/v1/pages/my	401 / 401	Пройдено
API9-07 Поиск статьи	GET /api/v1/pages/search?categoryId=1&search=LAB9&fuzzySearch=false	200 / 200	Пройдено
API9-08 Поиск статьи без авторизации	GET /api/v1/pages/search?categoryId=1&search=LAB9&fuzzySearch=false	401 / 401	Пройдено
API9-09 Создание статьи	POST /api/v1/pages/new	201 / 201	Пройдено
API9-10 Создание статьи без авторизации	POST /api/v1/pages/new	401 / 401	Пройдено
API9-11 Изменение статьи	PUT /api/v1/pages/12	200 / 200	Пройдено
API9-12 Изменение статьи без авторизации	PUT /api/v1/pages/12	401 / 401	Пройдено
API9-13 Добавление тега	POST /api/v1/pages/12/keywords	200 / 200	Пройдено
API9-14 Добавление тега без авторизации	POST /api/v1/pages/12/keywords	401 / 401	Пройдено
API9-15 Удаление тега	DELETE /api/v1/pages/12/keywords	204 / 204	Пройдено
API9-16 Удаление тега без авторизации	DELETE /api/v1/pages/12/keywords	401 / 401	Пройдено
API9-17 Список комментариев	GET /api/v1/pages/9/comments	200 / 200	Пройдено
API9-18 Список комментариев без авторизации	GET /api/v1/pages/9/comments	401 / 401	Пройдено
API9-19 Создание комментария	POST /api/v1/pages/9/comments	201 / 201	Пройдено

№ и сценарий	Метод и путь	Ожидание / факт	Итог
API9-20 Создание комментария без авторизации	POST /api/v1/pages/9/comments	401 / 401	Пройдено
API9-21 Изменение комментария	PUT /api/v1/pages/9/comments/15	200 / 200	Пройдено
API9-22 Изменение комментария без авторизации	PUT /api/v1/pages/9/comments/15	401 / 401	Пройдено
API9-23 IDOR: B изменяет комментарий A	PUT /api/v1/pages/9/comments/15	403 / 403	Пройдено
API9-24 Комментарий после IDOR-проверки	GET /api/v1/pages/9/comments	200 / 200	Пройдено
API9-25 Удаление комментария	DELETE /api/v1/pages/9/comments/15	204 / 204	Пройдено
API9-26 Удаление комментария без авторизации	DELETE /api/v1/pages/9/comments/15	401 / 401	Пройдено
API9-27 Удаление статьи	DELETE /api/v1/pages/12	204 / 204	Пройдено
API9-28 Удаление статьи без авторизации	DELETE /api/v1/pages/12	401 / 401	Пройдено
API9-29 Несуществующая статья	GET /api/v1/pages/2147483647	404 / 404	Пройдено
API9-30 Пустой комментарий	POST /api/v1/pages/9/comments	400 / 400	Пройдено
API9-31 Создание по Swagger без необязательных id и userId	POST /api/v1/pages/new	201 / 400	Не пройдено

В негативных запросах без авторизации менялось одно условие — отсутствие Bearer-токена; метод, адрес и тело сохранялись. Дополнительно проверены отсутствующая статья и пустой комментарий. Выполнена 31 проверка: 30 пройдены, одна выявила расхождение контракта.

Проверка объектной авторизации

Пользователь A создал специальный комментарий LAB9-A-команда к собственной учебной статье №9 и успешно изменил его. Затем в таком же PUT-запросе использован токен пользователя B той же роли User. Выполнена одна попытка записи маркера LAB9-IDOR-B: сервер вернул 403. Повторное чтение от имени A подтвердило, что остался текст LAB9-A-изменено; маркер B не записан. IDOR в этом сценарии не подтверждён. После проверки комментарий удалён владельцем.

Обнаруженный дефект

Поле	Содержание
ID и заголовок	KB-API-01 Создание статьи по опубликованной схеме Swagger отклоняется из-за неописанных обязательных полей
Окружение	Windows 11; Chromium 139.0.7258.5; KnowBase backend 1.0.0 и frontend 1.0.0; интерфейс https://127.0.0.1:5173; API http://127.0.0.1:8080; дата проверки 22.10.2026; обычные учебные пользователи labteam_a и labteam_b. Bruno CLI; контракт /swagger/v1/swagger.json.
Предусловия	Авторизован обычный пользователь A. В Swagger у PageDto отсутствует список required.
Шаги	1. Открыть схему PageDto. 2. Отправить POST /api/v1/pages/new с title, content и categoryId, без id и userId. 3. Сравнить ответ со схемой.
Ожидаемый результат	Запрос, соответствующий опубликованной схеме, принимается; либо Swagger явно объявляет обязательные поля id и userId.
Фактический результат	HTTP 400: missing required properties including id, userId. Передача id=0 и userId=0 позволяет создать статью с HTTP 201.
Серьёзность	Minor: интеграция по Swagger требует неописанных полей; обход доступен, основные операции работают.
Доказательство	API9-31 в api-results.json и схема PageDto в swagger.json; пароли и токены не включены.

Выводы

Проверены 13 операций API статей, комментариев, тегов и поиска. Из 31 проверки успешно выполнены 30. Интерфейс корректно отображал создание, редактирование и удаление комментария, а обновление страницы подтвердило сохранение данных. В позитивных пользовательских сценариях необработанные ошибки JavaScript не зарегистрированы. Попытка пользователя B изменить комментарий A отклонена ответом 403, поэтому IDOR в проверенном сценарии не подтверждён. Обнаружено расхождение Swagger и фактической обязательности полей при создании статьи, затрудняющее интеграцию API-клиентов. Основной проверенный объём работоспособен, но контракт создания статьи требует исправления.